



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全⁺命运共同体

真实场景下的 虚拟机逃逸

唐青昊

360 云安全研究部
360 Marvel Team

360 MARVEL TEAM（云安全研究部）聚焦于研究云安全中崭新的攻击面和防御方案。

在过去一年中，在虚拟化系统漏洞挖掘工具，真实环境中的虚拟机逃逸工具，虚拟化漏洞防御系统3个方面进行了探索。



目录

- qemu漏洞在kvm和xen场景下的利用
- docker远程攻击和安全机制绕过
- 针对漏洞利用程序的防御方案



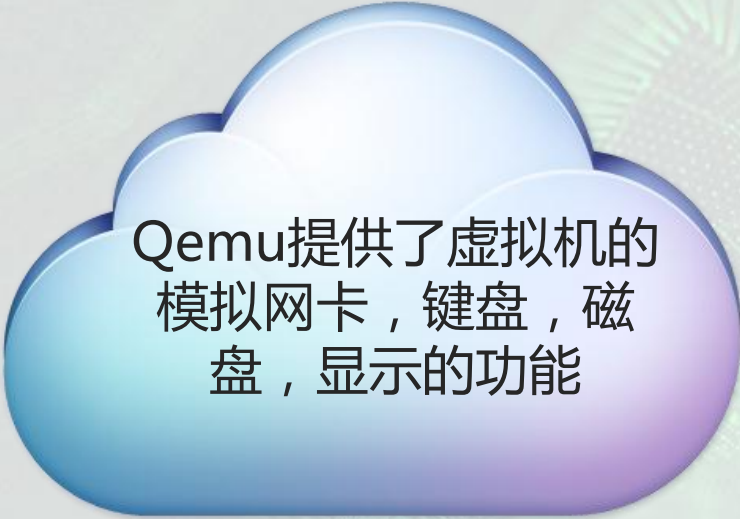
中国互联网安全大会



360互联网安全中心

QEMU漏洞在KVM和 XEN场景下的利用

Qemu在目前的云架构中广泛使用

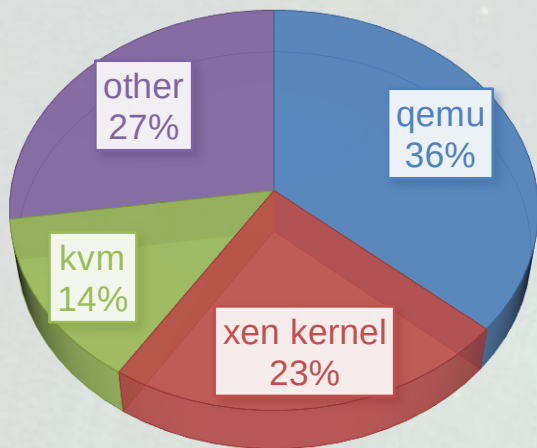


Qemu提供了虚拟机的
模拟网卡，键盘，磁
盘，显示的功能

- 正在使用的公有云和私有云解决方案大多使用该软件
- Qemu软件会直接处理虚拟机的各种操作，连接了虚拟机和宿主机，是云架构中的软肋

Qemu是目前漏洞高发区

开源虚拟化系统漏洞分布



Qemu软件漏洞危害

- 使宿主机拒绝服务
- 控制宿主机执行任意命令
- 窃取宿主机上其他虚拟机信息
- 可作为跳板，入侵云管理平台

Qemu漏洞局限性和对应解决方法

- 非默认设备漏洞占比例大 -> 使用默认设备漏洞
- Qemu进程权限较小 -> 使用提权漏洞

Qemu漏洞利用的整体流程

Step 1

进入虚拟机

- 1.网站入侵
- 2.服务端软件入侵
- 3.购买云主机

Step 2

定位虚拟化系统类型和版本

- 1.通过虚拟机启动信息

```
max@localhost:/home/max
File Edit View Search Terminal Help
[root@localhost max]# dmesg | grep -i "Xen version"
Xen version: 4.4.3 (preserve-AD)
```

- 2.通过api，如hypercall

Step 3

在漏洞代码中加入载荷

- 1.Shell反弹
- 2.虚拟机快照窃取
- 3.内网探测

Step 4

执行漏洞利用代码，获取反馈

Qemu漏洞利用程序的四个关键阶段

1.保存利用前环境

2.读取libc中函数地址，填充shellcode

CVE-2016-2538 ， CVE-2016-3710

3.劫持执行逻辑，分配内存或者使用未使用的内存，修改内存

属性，复制shellcode到目标内存空间，执行shellcode

CVE-2015-7504

CVE-2016-3710

4.还原到利用前状态

Qemu漏洞利用程序的四个关键阶段

可被越界读写的内存

```
1 7ffff2000000-7ffff3000000 rw-p 00000000 00:00 0
2 7ffff3000000-7ffff3001000 ---p 00000000 00:00 0
3 7ffff30ff000-7ffff3200000 rw-p 00000000 00:00 0
4 7ffff3200000-7ffff3220000 rw-p 00000000 00:00 0
5 7ffff3220000-7ffff3221000 ---p 00000000 00:00 0
6 7ffff32ff000-7ffff3400000 rw-p 00000000 00:00 0
7 7ffff3400000-7ffff3440000 rw-p 00000000 00:00 0
8 7ffff3440000-7ffff3441000 ---p 00000000 00:00 0
9 7ffff345c000-7ffff357e000 rw-p 00000000 00:00 0
10 7ffff357e000-7ffff3581000 rw-s 00000000 00:09 4542      kvm-vcpu
11 7ffff3581000-7ffff3582000 rw-s 00000000 00:04 166984    /dev/zero (deleted)
12 7ffff3582000-7ffff3583000 ---p 00000000 00:00 0
13 7ffff3583000-7ffff48af000 rw-p 00000000 00:00 0
14 7ffff48af000-7ffff48b0000 ---p 00000000 00:00 0
15 7ffff48b0000-7ffff53b1000 rw-p 00000000 00:00 0
16 7ffff53b1000-7ffff53b4000 rw-s 00000000 00:04 166975    /dev/zero (deleted)
17 7ffff53b4000-7ffff54a5000 rw-p 00000000 00:00 0
18 7ffff54a5000-7ffff54a6000 ---p 00000000 00:00 0
19 7ffff54a6000-7ffff5ea6000 rw-p 00000000 00:00 0
20 7ffff5ea6000-7ffff6030000 r-xp 00000000 fd:00 65758     /lib64/libc-2.12.so
21
```

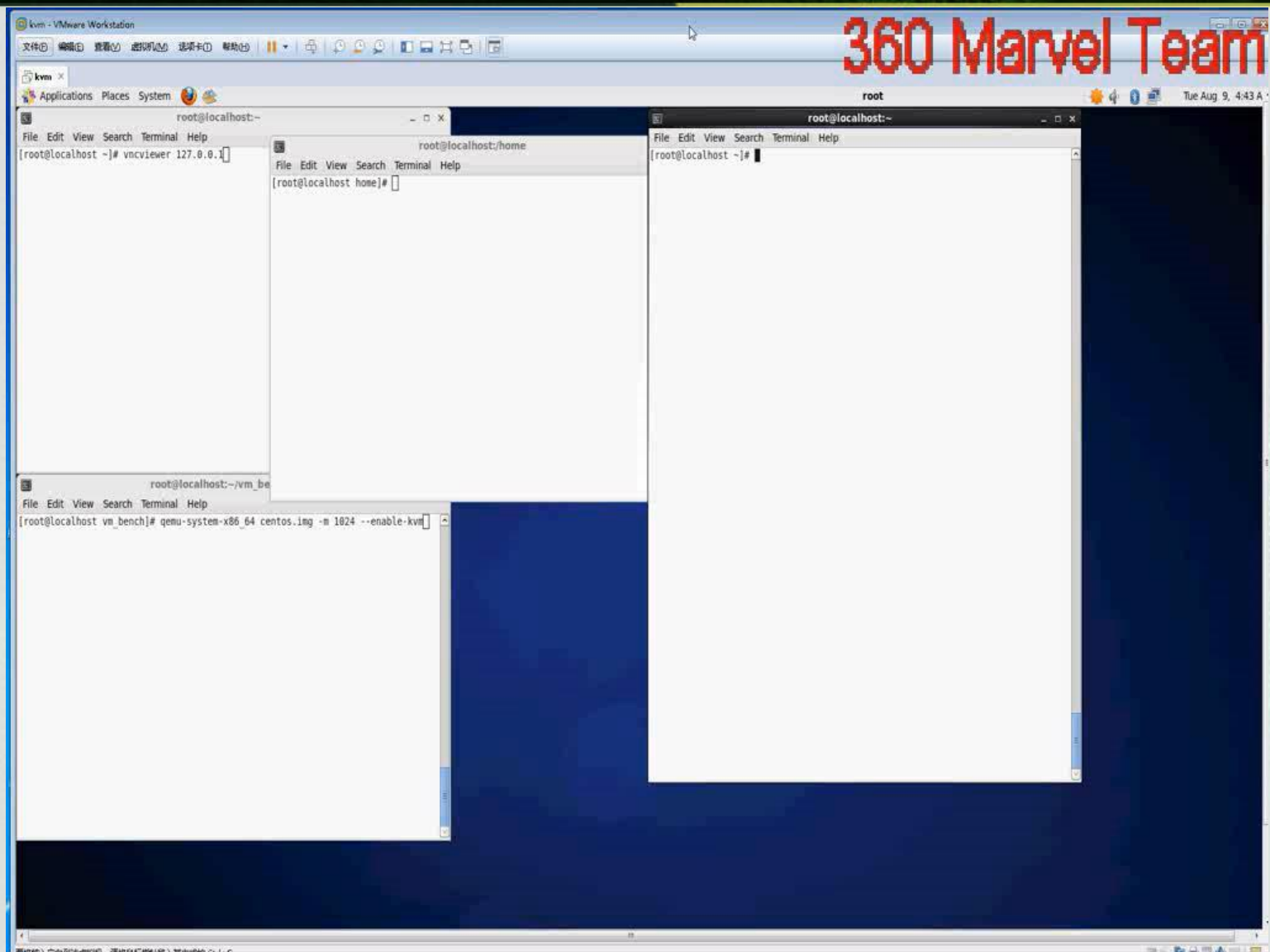
s->vram_ptr

注意：内存空间是不连续的

Lib内存开始

越界之后可读写的内存范围

CVE-2016-3710漏洞利用视频





中国互联网安全大会



360互联网安全中心

DOCKER的远程攻击和 安全机制绕过

container breakout原理和关键步骤

- 1.使用linux kernel提权漏洞进入内核上下文
- 2.获取当前进程task struct
- 3.回溯task list获取pid=1的task struct , 复制其关键数据
- 4.切换当前namespace
- 5.打开root shell , 完成breakout

docker 安全机制 – Seccomp特性及突破

全称Security computing mode , 是linux kernel feature (seccomp-bpf) , 进程必须按照配置策略过滤系统调用。

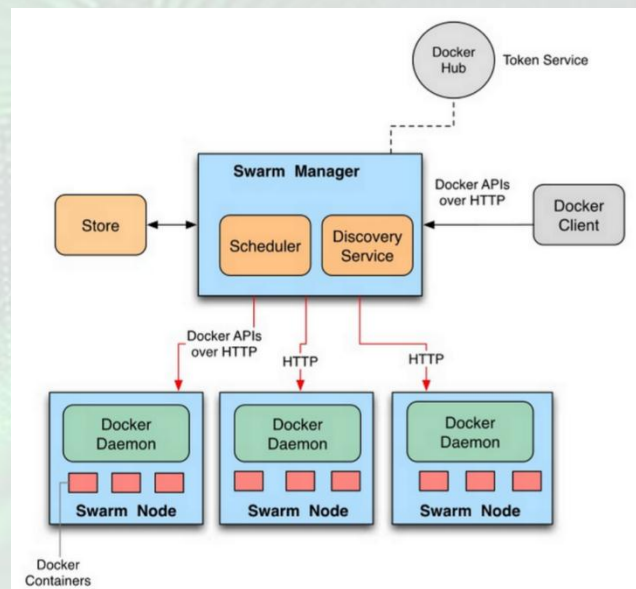
该特性实现了容器的syscall白名单化 , 极大减少了linux kernel提权漏洞成功的几率。

Syscall	Description
acct	Accounting syscall which could let containers disable their own resource limits or process accounting. Also gated by CAP_SYS_PACCT .
add_key	Prevent containers from using the kernel keyring, which is not namespaced.
adjtimex	Similar to clock_settime and settimeofday , time/date is not namespaced.
bpf	Deny loading potentially persistent bpf programs into kernel, already gated by CAP_SYS_ADMIN .
clock_adjtime	Time/date is not namespaced.
clock_settime	Time/date is not namespaced.
clone	Deny cloning new namespaces. Also gated by CAP_SYS_ADMIN for CLONE_* flags, except CLONE_USERSNS .
create_module	Deny manipulation and functions on kernel modules.
delete_module	Deny manipulation and functions on kernel modules. Also gated by CAP_SYS_MODULE .
finit_module	Deny manipulation and functions on kernel modules. Also gated by CAP_SYS_MODULE .
get_kernel_syms	Deny retrieval of exported kernel and module symbols.
get_mempolicy	Syscall that modifies kernel memory and NUMA settings. Already gated by CAP_SYS_NICE .
init_module	Deny manipulation and functions on kernel modules. Also gated by CAP_SYS_MODULE .

如图是部分被排除在白名单之外的系统调用。只能使用白名单syscall漏洞才能完成提权。如cve-2014-0038 , 使用recvmsg syscall。

docker swarm配置风险

- Swarm是docker集群管理工具，接收客户端请求运行容器
- 错误配置导致监听2375端口
- 远程攻击者连接主机执行docker命令，包括在容器中执行命令
- 最严重的威胁是远程入侵，并breakout，实现远程命令执行



Swarm原理图

1	104.40.138.*	104.40.140.*	104.40.145.*
2	104.41.202.*	104.41.211.*	104.47.143.*
3	128.199.51.*	130.185.253.*	130.192.85.*
4	134.119.13.*	134.213.218.*	134.60.79.*
5	139.201.155.*	138.201.157.*	139.59.128.*

受该风险影响的部分欧美ip列表

完整逃逸视频

```
root@2aeb44310d8a: /tmp
文件(F) 编辑(E) 查看(V) 选项(O) 传输(T) 脚本(S) 工具(L) 窗口(W) 帮助(H)
输入主机: <Alt+R>
MarvelTeam@Qihoo 360

root@2aeb44310d8a: /tmp x
vsec@vsec-virtual-machine:~$
vsec@vsec-virtual-machine:~$
vsec@vsec-virtual-machine:~$
vsec@vsec-virtual-machine:~$ ifconfig
docker0  Link encap:Ethernet  HWaddr 02:42:08:7e:27:65
          inet addr:172.17.0.1  Bcast:0.0.0.0  Mask:255.255.0.0
          UP BROADCAST MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:0 (0.0 B)  TX bytes:0 (0.0 B)

ens160    Link encap:Ethernet  HWaddr 00:50:56:8d:3b:86
          inet addr:10.16.60.71  Bcast:10.16.61.255  Mask:255.255.254.0
          inet6 addr: fe80::e409:7f50:30e6:c5fa/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:42767 errors:0 dropped:70 overruns:0 frame:0
          TX packets:16180 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10908381 (10.9 MB)  TX bytes:1979234 (1.9 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:330 errors:0 dropped:0 overruns:0 frame:0
          TX packets:330 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:24832 (24.8 KB)  TX bytes:24832 (24.8 KB)

vsec@vsec-virtual-machine:~$
vsec@vsec-virtual-machine:~$
```

就緒 ssh2: AES-256-CTR 32, 30 60 行, 156 字 Linux 大写 数字 14:33 2016/8/9



中国互联网安全大会



360互联网安全中心

虚拟化系统漏洞 防御思路

用户身份鉴别

- 1.日常数据采集：登陆地址，操作行为
- 2.异常数据报警：异常监听端口，异常地址，异常上传和执行行为

虚拟化系统加固

- 1.定期打重要漏洞补丁：kernel补丁，虚拟化系统补丁
- 2.热补丁系统**
- 3.删除虚拟机中有关虚拟化系统类型和版本的信息

漏洞利用程序阻断系统：

- 1.针对每一个漏洞对应规则的阻断
- 2.针对漏洞利用过程关键阶段和数据的阻断

Q&A



中国互联网安全大会



360互联网安全中心





谢谢